Compliance Assessment Report: From WannaCry to a Cybersecurity Governance Plan

Tommaso Rinaldi

1983126

Contents

1. Introduction of the Scenario & Assumptions 1
1.1 Scenario Overview 1
1.2 Operational Assumptions 1
2. Assessment Methodology 2
2.1 Scope and Framework Selection 2
2.2 Evaluation Scales 2
2.3 Evidence Considered 3
3. Control Assessment 4
4. Profile Assessment 5
5. Conclusion & Strategic Recommendations 6
5.1 Post-Incident Root Cause Analysis 6
5.2 Strategic Remediation Roadmap 6
5.3 Executive Summary: The Reality Behind Existing Controls 7

1. Introduction of the Scenario & Assumptions

1.1 Scenario Overview

The target organization is a large healthcare provider operating a complex and distributed infrastructure comprising approximately 2,000 Windows endpoints, 80 servers, and multiple information systems supporting both clinical operations and administrative services. While IT management is nominally centralized, several departments autonomously manage specialized departmental systems.

The organization exhibits critical operational gaps in its security posture:

- Lack of a complete, continuously updated hardware and software asset inventory;
- A vulnerability management process that relies heavily on manual patch deployment;
- Several clinical and mission-critical systems left unpatched due to application compatibility or availability concerns;
- An incident response procedure that has never been validated through a large-scale simulation or exercise.

In May 2017, despite Microsoft having already issued a security update addressing the underlying SMBv1 vulnerability (MS17-010), the organization fell victim to the WannaCry ransomware worm. Within hours of the initial detection, the infection spread across the network, locking machines, demanding ransoms, and severely disrupting patient care and administrative functions.

1.2 Operational Assumptions

To establish a concrete baseline for this assessment, the following technical and architectural assumptions are made:

- **Flat Network Architecture:** The internal network lacks granular zoning or micro-segmentation; no internal firewalls or Access Control Lists (ACLs) were in place to restrict lateral SMB traffic (TCP port 445) between administrative workstations and clinical VLANs.
- **Legacy and Embedded Systems:** Many endpoint devices integrated with medical instruments or diagnostic machinery run unsupported, legacy operating systems (e.g., Windows XP, Windows Server 2003) for which updates were unavailable or not certified by medical device manufacturers.
- **Network-Accessible Backups:** While backup procedures exist, storage volumes and network shares were directly accessible from the infected domain without immutability or physical air-gapping, resulting in backup corruption or rapid encryption.
- **Broad Local Administrative Privileges:** Healthcare staff and clinical software regularly operate with elevated local administrator rights to

circumvent legacy software compatibility issues, facilitating automated script execution and lateral malware propagation.

2. Assessment Methodology

2.1 Scope and Framework Selection

The assessment evaluates the organization's governance, preventive measures, and operational readiness before and during the WannaCry outbreak. To ensure depth without unnecessary overhead, a targeted subset of 6 key controls was selected across two complementary standards:

1. **NIST SP 800-53 Rev. 5:** Utilized for the technical and operational control assessment.
2. **National Framework for Cybersecurity and Data Protection (Italian CSF - 2025 Edition / NIST CSF 2.0 Core):** Utilized for the organizational profile assessment (Current Profile vs. Target Profile).

The controls were chosen because they directly correspond to the critical attack vectors, propagation mechanics, and recovery failures observed in the WannaCry incident (asset discovery, patching, network boundaries, response testing, and backup integrity).

2.2 Evaluation Scales

To ensure an objective evaluation, standardized rating scales were adopted:

- **Control Implementation Scale (NIST SP 800-53):**
  - **Not Implemented (NI):** The control is either completely missing or structurally incapable of mitigating the threat.
  - **Partially Implemented (PI):** The control is documented or executed ad-hoc/manually, but lacks comprehensive coverage, automation, or continuous enforcement.
  - **Implemented (I):** The control is formally defined, automated, continuously monitored, and consistently applied organization-wide.
- **Maturity Profile Scale (Italian CSF / CSF 2.0 Tiers):**
  - **Tier 1 (Partial / Informal):** Practices are reactive, uncoordinated, and rely on manual intervention.
  - **Tier 2 (Risk-Informed):** Procedures exist on paper but lack cross-departmental coordination or systemic enforcement.
  - **Tier 3 (Repeatable / Standardized):** Comprehensive, formal, automated, and regularly tested processes integrated into enterprise governance.

2.3 Evidence Considered

The evaluation is supported by factual evidence extracted directly from the incident timeline:

- Partial departmental ownership and lack of centralized visibility across 2,000 workstations and 80 servers;
- Failure to deploy security patch MS17-010 over two months after its public release;
- Unrestricted worm propagation throughout Friday morning;
- Complete operational paralysis caused by the inability to rapidly contain the outbreak or restore clean data.

3. Control Assessment

The table below provides a compact summary of the technical assessment conducted on the selected NIST SP 800-53 controls:

Control ID & Title	Status	Assessment Rationale & Case Evidence
CM-8: Information System Component Inventory	**PI**	Even though there is a central IT team, several clinical departments buy and manage their own hardware independently. Without continuous, automated asset discovery, IT simply can’t see the true attack surface across those 2,000 endpoints.
SI-2: Flaw Remediation	**PI**	Microsoft pushed out the fix before the attack hit, but rolling out patches is still mostly manual. Because teams couldn't afford downtime and had no automated testing pipeline, critical machines were left unpatched and vulnerable.
RA-5: Vulnerability Monitoring and Scanning	**PI**	A vulnerability management process exists on paper, but scheduled scans miss unpatched systems and fail to flag active SMBv1 services across independent department devices.
SC-7: Boundary Protection	**NI**	The internal network had zero segmentation. Because internal firewalls didn't block port 445 between clinical and administrative zones, the EternalBlue exploit spread unchecked across the entire hospital.
IR-3: Incident Response Testing	**NI**	While an incident response plan was documented, it had never been tested through drills or tabletop simulations. When the attack hit on Friday, the team had no muscle memory or practiced steps for isolating systems, triaging alerts, and containing the threat.
CP-9: Information System Backup	**PI**	Backups were running regularly, but they lacked immutable or air-gapped offline storage. Once the incident unfolded, it quickly became clear that restoring bare-metal clinical databases at speed was completely out of reach under crisis conditions.

4. Profile Assessment

Using the Italian Framework Core (FNCDP 2025 / CSF 2.0), the organization's posture at the time of the incident (**Current Profile - May 2017**) is contrasted against the baseline necessary for a resilient healthcare environment (**Target Profile**):

CSF / FNCDP Subcategory	Current Profile	Target Profile	Gap Analysis
ID.AM-01: Physical devices and systems inventory	**Tier 1**	**Tier 3**	Shadow IT runs rampant across departments. Reaching Tier 3 maturity will require rolling out automated Network Access Control (NAC) alongside centralized asset management software.
ID.RA-01: Asset vulnerabilities are identified and documented	**Tier 1**	**Tier 3**	Vulnerability scanning is spotty at best. Moving forward, the hospital needs continuous, credentialed scans paired with automated risk scoring that prioritizes fixes based on direct impact to patient care.
PR.PS-02: Software is maintained, patched, or replaced	**Tier 1**	**Tier 3**	Manual patching simply can't keep pace with automated exploits. Reaching Tier 3 requires centralized patch orchestration, staged testing pipelines, and explicit compensating controls for systems too old to update.
PR.IR-01: Networks and environments are protected	**Tier 1**	**Tier 3**	The internal network effectively runs as a single flat broadcast domain. To fix this, we must enforce granular micro-segmentation, isolate medical devices into dedicated VLANs, and apply strict ingress and egress port filtering across all zones.
RS.MA-01: Incident management plan is executed	**Tier 1**	**Tier 3**	The incident response plan exists only on paper. Achieving Tier 3 maturity demands regular functional drills, realistic tabletop exercises, and unambiguous operational containment triggers such as clear protocols for immediate network isolation.
RC.RP-03: Integrity of backups and restoration assets	**Tier 1**	**Tier 3**	Recovery systems were neither isolated nor tested for rapid, large-scale restoration. Surviving ransomware requires adopting a strict 3-2-1 backup strategy with immutable, air-gapped copies that attackers cannot compromise.

5. Conclusion & Strategic Recommendations

5.1 Post-Incident Root Cause Analysis

The disruption of hospital operations was not caused by an absence of policy, but by an unsustainable gap between written governance and day-to-day operational realities:

- **Unmonitored Shadow IT:** Security governance cannot protect what it cannot see. Independent procurement across clinical units created blind spots that left unmanaged, unmonitored devices exposed as prime infection footholds.
- **The Pitfall of Manual Patching:** Relying on manual updates across thousands of endpoints produced an insurmountable maintenance backlog. Even with vendor fixes available months in advance, high-risk machines remained unprotected.
- **Unshielded Legacy Equipment:** Critical medical systems that could not be updated due to compatibility concerns were placed directly on the open corporate network, without compensating barriers like isolated VLANs or disabled legacy protocols.
- **Preparedness Confined to Paper:** Having documented incident plans without conducting regular drills created an illusion of security that broke down as soon as teams faced an active, fast-moving crisis.

5.2 Strategic Remediation Roadmap

To shift from reactive compliance to verifiable resilience, the hospital must execute the following phased interventions:

1. **Immediate Isolation (Quick Wins):** Enforce an enterprise-wide Group Policy to disable SMBv1 and configure internal firewall rules to block TCP port 445 between subnets, shutting down lateral propagation paths.
2. **Automated Discovery and Patching:** Deploy an automated asset discovery and patch orchestration platform to continuously inventory connected devices and deploy validated updates without disrupting patient care.
3. **Internal Micro-Segmentation:** Dismantle the flat broadcast domain by carving clinical instruments, diagnostic systems, and administrative workstations into dedicated, firewalled VLANs governed by strict zero-trust access controls.
4. **Resilient, Air-Gapped Backups:** Enforce the 3-2-1 backup standard with verified immutable, offline storage, validated through quarterly bare-metal restoration drills on core clinical databases.
5. **Operational Drills:** Conduct biannual tabletop exercises and practical containment simulations across technical teams and hospital leadership, building the muscle memory needed to isolate active compromises immediately.

5.3 Executive Summary: The Reality Behind Existing Controls

When leadership asks **how an incident of this scale occurred despite active security policies and controls**, the answer lies in the fundamental difference between formal compliance and operational defense:

- **Policies cannot outrun automated exploits.** A documented guideline functions on human timelines, but self-propagating threats execute in milliseconds. Fragmented, manual interventions will always lose the race against automated worms.
- **Defense-in-depth requires architectural boundaries.** Policies offer zero protection inside a flat network. Without segmentation, a perimeter breach on a single administrative machine becomes an unobstructed path to hospital-wide disruption.
- **Known risks require compensating safeguards.** Knowing that sensitive clinical equipment cannot be patched is not a defense—it is an operational reality that demands dedicated countermeasures, such as protocol filtering and isolated enclaves.
- **Untested plans fail under pressure.** A procedure that has never been tested in a realistic crisis drill is an unverified assumption. Without regular live-fire practice, response teams cannot execute rapid triage and emergency containment when seconds count.

Ultimately, effective cybersecurity governance cannot end with a policy binder or a compliance audit. True resilience requires 24/7 visibility into every connected asset, automated security hygiene, deliberate architectural segmentation, and protocols proven to hold under pressure.